OPENSEC STUDIO V1.10.10 OFFICIAL RELEASE

OpenSec Studio 公式図解ユーザーマニュアル

開発者とDevSecOpsのためのサイバーセキュリティ＆Web診断スイート入門



創設者 & 首席ソフトウェアアーキテクト

el saghet

2026年10月

OpenSec Security Engineering

📚 目次 (Contents)

1. 📖 **プロローグ: インターネットの大村 (The Internet Village)**
2. **第 1章:** 初回起動と画面構成 (Screen Anatomy)
3. **第 2章:** ダッシュボード (Dashboard)
4. **第 3章:** 税関の門番 (HTTP インターセプター & HTTPS トンネル)
5. **第 4章:** 航海日誌 (HTTP 履歴 / History)
6. **第 5章:** 魔法のコピー機 (ネイティブ Rust リピーター)
7. **第 6章:** 鍵テストロボット (Intruder / ブルートフォース)
8. **第 7章:** セキュリティ監査官 (DAST スキャナー & YAML)
9. **第 8章:** ドアノックと鍵師 (ポートスキャン & SSH 監査)
10. **第 9章:** 魔法のレシピ集 (Nuclei-Style YAML テンプレート)
11. **第 10章:** 万能翻訳機 (デコーダー / Decoder)
12. **第 11章:** 部品検査官 (SCA 依存関係リアルタイム監査)
13. **第 12章:** 宝の地図 (SiteMap & JS スパイダー)
14. **第 13章:** スパイ郵便配達員 (OAST コラボレーター)
15. **第 14章:** タイムマシンと裁判官 (Diffing & PCI-DSS 監査)
16. **第 15章:** 秘密の大百科事典 (オフライン CVE フィード)
17. **第 16章:** 秘密ミッション金庫 (.opensec プロジェクト保存)
18. **第 17章:** 拡張ツールショップ (BApp コミュニティストア)
19. **第 18章:** SSL証明書、60日間評価期間、BTC $30 寄付 & 公式クレジット
20. **第 19章:** クラウド星図 (CloudGraph: CNAPP、Wiz エンジン、DSPM & SIEM ハブ)

📖 プロローグ: インターネットの大村 (The Internet Village)

> **🏘️ 手紙とお店のたとえ話**
>
> **インターネット**を、たくさんの家や商店が立ち並ぶ大きな村だと想像してみてください：
>
> - **Webブラウザ:** 通りを歩いて買い物や注文をする「あなた自身」です。
> - **Webサーバー:** カウンター越しにお客さんを迎える「お店」です。
> - **HTTPリクエスト (要求):** *「おもちゃのカタログを見せてください」* と書いた「手紙」です。
> - **HTTPレスポンス (返答):** お店が返してくれる「小包や商品」です。

OpenSec Studio とは？

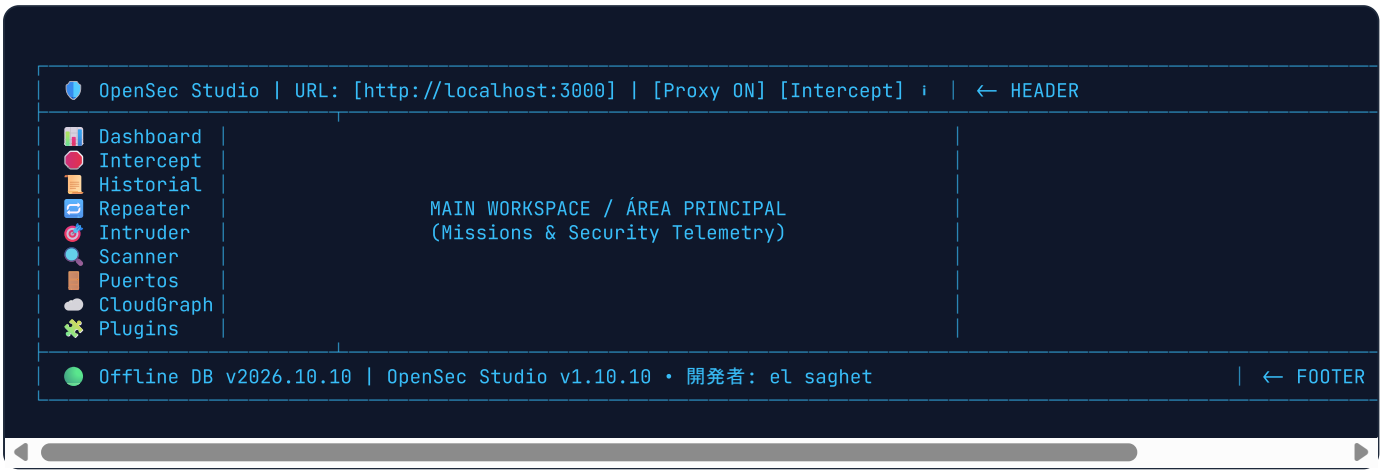
el saghet によって作られた、あなたの「魔法の探偵リュック」です。手紙を空中でキャッチして書き換える (Interceptor)、手紙を瞬時に千回コピーして送る (Repeater)、千本の鍵を連続テストする (Intruder)、お城の窓やドアの施錠を調べる (Scanner)、安全な通信路を開拓するポートスキャン & SSHホスト監査、そしてオフラインで1,200種類以上の脅威を調べられる大百科事典 (Offline Feed) が詰まっています。

> **🌟 基本理念: 100% リアル、シミュレーション一切なし**
>
> OpenSec Studio では飾りやダミーのボタンは一つもありません。すべての操作がネイティブの Rust コードを実行し、本物のネットワークパケットを送受信します。

第 1章: 初回起動と画面構成 (Screen Anatomy)

デスクトップの `OpenSec Studio.exe` をダブルクリックします。瞬時に高速起動します。

画面インターフェースの全体図:



セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
1. ヘッダー (上部バー)	対象URL入力、プロキシ開始/停止、インターセプト切替、情報 (ℹ️)。	車のハンドルとダッシュボード。
2. サイドバー (左メニュー)	全18個のセキュリティモジュールへ瞬時に移動。	整頓された道具ラック。
3. メイン作業エリア	リクエスト編集、パケット履歴、解析グラフ、診断レポート。	探偵の手術台と実験デスク。

> 🕵️ **探偵ミッション 1: 公式クレジットの確認**
> 右上の ℹ️ アイコンをクリックしてください。バージョン **v1.10.10** と開発者 **el saghet** の証が表示されます。

第 2章: ダッシュボード (Dashboard)

診断中のトラフィックとセキュリティ状態をリアルタイム集約。

> 🚗 **スピードメーターと計器パネル**
> 車のメーターのように、通信速度、エンジンの稼働、注意すべき危険度を一目で伝えます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
総リクエスト数	検査したパケットの累計カウント。	車の走行距離計。
重大な脆弱性	即時対処が必要な危険の赤色アラート。	エンジンの警告ランプ。
セキュリティ指数	対象Webアプリの総合健全度スコア。	車の総合コンディション。

> 🕵️ **探偵ミッション 2: レーダーの起動**
> メインプロキシのスイッチをクリックします。状態が鮮やかな緑色の「稼働中」に切り替わります。

第 3章: 税関の門番 (HTTP インターセプター & HTTPS トンネル)

ブラウザとサーバーの間に入り、手紙が飛ぶ前に空中で一時停止させます。

> 🛑 **メモ帳を持った親切な税関審査官**
> 手紙が発送される直前に中身を読み、鉛筆で文字を書き換え、通す (Forward) か破棄する (Drop) か判断できます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
Intercept ON / OFF	パケットの一時停止機能を有効化または解除。	料金所のバーを上げ下げする。
Forward (通過)	編集した手紙を目的のサーバーへ送信。	検査をパスした車を通す。
Drop (破棄)	通信を即座に中断して破棄。	怪しい荷物を没収して廃棄する。

> 🕵️ **探偵ミッション 3: 空中で手紙を書き換える**
> インターセプトをONにし、ブラウザで送信したデータの一部を書き換えてから Forward を押してみましょう。

第 4章: 航海日誌 (HTTP 履歴 / History)

送受信されたすべての通信を詳細に記録する不変ログ。

> 📜 **宮廷記録官の公式台帳**
> 送られたすべての手紙が時間、メソッド、URL、サイズ、応答コードとともに色分け記録されます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
200 OK (緑色)	注文が問題なく処理された成功コード。	荷物が無事に配達された。
404 / 403 (橙色)	ページが存在しない、または施錠中。	宛先不明、または立入禁止。
500 エラー (赤色)	サーバー内部で起きた故障。	お店のバックヤードでボヤ騒ぎ。

> 🕵️ **探偵ミッション 4: 重要通信の絞り込み**
> 履歴の検索バーに "/api" と入力し、Web API の通信だけを抽出してみましょう。

第 5章: 魔法のコピー機 (ネイティブ Rust リピーター)

Rust のネイティブソケット経由で本物のHTTPパケットを高速反復送信。

> 🔁 **瞬時クローン製造マシン**
> フォームを100回打ち直す代わりに、ヘッダーを1文字変えてボタン一つで何度でも再送できます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
マルチタブ	複数のリクエストを同時に作業。	机の上に複数の手紙を並べる。
Send ボタン	ネイティブ Rust エンジンで実パケットを発射。	コピー機のスタートボタン。
分割ビュー	左にリクエスト、右にサーバーの応答。	手紙と返事の見比べ。

> 🕵️ **探偵ミッション 5: 隠しヘッダーの観察**
> テストURLへリクエストを送信し、ミリ秒単位の正確な応答時間を確認してください。

第 6章: 鍵テストロボット (Intruder / ブルートフォース)

辞書ファイルを用いた自動化ファジングと高速パケット送信エンジン。

> **超高速な鍵師アンドロイド**
> 袋に入った1,000本の鍵をロボットが瞬時に差し替え、どの鍵で鍵穴が開くか自動判定します。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
マーカー §payload§	差し替えたい位置を指定。	鍵穴の位置に赤い印をつける。
スナイパーモード	1か所ずつ順番に単語リストを試す。	1つの標的を正確に狙う狙撃手。
クラスターボム	IDとパスワードのすべての組み合わせを総当たり。	すべての鍵穴にすべての鍵を試す。

探偵ミッション 6: 隠しフォルダの発見
パス辞書 (admin, login など) を設定して実行し、サイズが異なる応答を見つけましょう。

第 7章: セキュリティ監査官 (DAST スキャナー & YAML)

OWASP Top 10、SQL インジェクション、XSS を検出する動的診断エンジン。

> **🔍 虫眼鏡とノートを持った名探偵**
> 家の壁や窓、鍵穴を一つ一つ調べ、施工ミスや施錠忘れがないかを調査します。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
パッシブスキャン	攻撃せず安全にヘッダーの不備を調査。	触らずに歩道から眺めて点検する。
アクティブスキャン	安全な検証パケットを送り実際に穴があるか調査。	ドアを優しくノックして確認する。
SARIF 出力	国際標準のセキュリティ診断レポート出力。	探偵の署名入り公式調査報告書。

🕵️ 探偵ミッション 7: セキュリティヘッダー監査

ローカルサーバーに対してスキャンを実行し、CSP (Content-Security-Policy) の有無を確認します。

第 8章: ドアノックと鍵師 (ポートスキャン & SSH 監査)

65,535個の全TCPポートを非同期スキャンし、SSH経由でホスト設定を監査。

> 🚪 **お城のすべてのドアベルを鳴らす**
> どのドア (80番 HTTP, 443番 HTTPS, 22番 SSH) が開いていて誰が応答するか調べます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
並行 TCP スキャン	Rust による超高速ポート調査。	探偵チーム全員で一斉にベルを鳴らす。
SSH ホスト監査	CIS ベンチマーク基準による OS 設定診断。	お城の内側の金庫室の頑丈さを調べる。

> 🕵️ **探偵ミッション 8: 開放ポートの特定**
> 127.0.0.1 の 80〜8088 番ポートをスキャンし、発見されたサービスを一覧確認します。

第 9章: 魔法のレシピ集 (Nuclei-Style YAML テンプレート)

業界標準の YAML 記法で独自の脆弱性検査ルールを記述・実行。

> 📜 **秘密の魔法調合法**
> 「この手紙を送り、この文字が返ってきたら危険」というルールを記したレシピです。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
構文ハイライトエディタ	構文エラーをリアルタイム検知。	魔法のインクで呪文を書く。
マッチャーと抽出器	文字列や正規表現による一致条件判定。	罠を見抜く特別な合言葉。

> 🕵️ **探偵ミッション 9: オリジナルルールの作成**
> /.git/HEAD の露出を調べるルールを作成し、バリデーターで構文をテストします。

第 10章: 万能翻訳機 (デコーダー / Decoder)

Base64、URL エンコード、16進数 (Hex)、ハッシュ値を自在に変換。

> 🔑 **探偵のロゼッタストーン**
> スパイが暗号で書いた暗号文を、瞬時に誰でも読める普通の言葉に翻訳します。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
URL エンコード	特殊文字をネット送信用に変換。	手紙を安全な封筒にパッキングする。
Base64 & Hex	バイナリデータを英数字文字列に変換。	暗号文字を普通の文字に戻す。
SHA-256 ハッシュ	改ざん不可能なデータの指紋を計算。	手紙の指紋を採取する。

> 🕵️ **探偵ミッション 10: Base64 の復号**
> Base64文字列を入力欄に貼り付け、「Decode as Base64」で元の文章を復元します。

第 11章: 部品検査官 (SCA 依存関係リアルタイム監査)

package.json などのライブラリ定義をスキャンし、既知の脆弱性を検知。

> **🧱 レンガと鉄骨の建築検査官**
> 家を建てた材料にリコール対象の不良品が混ざっていないかチェックします。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
CVE データベース照合	パッケージと脆弱性情報を瞬時にマッチング。	欠陥部品カタログと照らし合わせる。
修正バージョンの提示	安全な推奨バージョンを案内。	建築士による部品交換の指示書。

🕵️ 探偵ミッション 11: package.json の監査
プロジェクトの package.json を読み込ませ、危険なライブラリ警告を確認します。

第 12章: 宝の地図 (SiteMap & JS スパイダー)

ブラウジングとJS解析から対象サイトの全エンドポイント階層ツリーを構築。

> 🗺️ **王国の詳細な地図**
> 村を歩くたびに、地図職人が路地、裏口、隠し倉庫を自動で地図に書き足していきます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
階層ツリー表示	ホスト、フォルダ、ファイルごとに整理。	家系図のような枝分かれ。
パッシブ JS 解析	スクリプトから隠された内部APIルートを発掘。	設計図の余白に書かれた秘密の抜け道を見つける。

> 🕵️ **探偵ミッション 12: サイト全体図の探索**
> プロキシ経由でWebサイトを巡回し、自動構築される SiteMap ツリーを観察します。

第 13章: スパイ郵便配達員 (OAST コラボレーター)

画面に結果が出ないブラインド脆弱性 (Blind SSRF, Log4Shell) を検知。

> **🔔 秘密のベルがついた罠**
> 相手に秘密の返信先を渡しておき、サーバーがそこにアクセスした瞬間にベルが鳴り響きます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
一意なドメイン生成	攻撃テストごとの追跡用識別子を発行。	罠に刻まれた秘密のシリアル番号。
DNS/HTTP 応答ログ	サーバーが罠を踏んだ時刻とIPをリアルタイム記録。	罠にかかったことを知らせるベルの音。

🕵️ 探偵ミッション 13: OAST の罠を仕掛ける
テスト用アドレスを発行し、サーバーからの外部問い合わせが届く様子を確認します。

第 14章: タイムマシンと裁判官 (Diffing & PCI-DSS 監査)

過去のスキャンと現在を比較し、PCI-DSS v4.0 基準のセキュリティ適合度を判定。

> ⚖️ **正義の天秤とタイムカプセル**
> 昨日の写真と今日の写真を比較し、直った箇所を褒め、新たな危険を注意します。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
脆弱性の差分比較	修正済み (Fixed)、新規 (New)、残存 (Persistent) に分類。	宿題の完了リストとやり残し。
PCI-DSS v4.0 適合度	クレジットカード業界基準の適合率を算出。	裁判官による公式通知表。

> 🕵️ **探偵ミッション 14: 2つの診断結果の比較**
> 過去の診断結果を2つ読み込ませ、修正された項目が緑色で表示されるのを確認します。

第 15章: 秘密の大百科事典 (オフライン CVE フィード)

1,200件以上の既知の脅威を5ミリ秒未満で超高速検索。オフライン完全対応。

> 📖 **リュックの中の秘密の大百科事典**
> ネットが繋がらない機内や地下シェルターでも、あらゆる脅威の手口を調べられます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
超高速インメモリ検索	待ち時間なしで瞬時に絞り込み。	探したいページが一瞬で開く本。
差分自動同期	ネット接続時に最新の脅威データを更新。	定期的に新しい巻を届けてくれる飛脚。

> 🕵️ **探偵ミッション 15: 有名な脅威の調査**
> 「Log4Shell」と検索し、攻撃手法と推奨修正コードを確認します。

第 16章: 秘密ミッション金庫 (.opensec プロジェクト保存)

調査中の通信ログ、メモ、設定を AES-256-GCM 暗号化で丸ごと保存・復元。

> 🔒 **探偵の頑丈な鋼鉄金庫**
> 今日の調査メモや証拠をすべて金庫にしまい、暗証番号で施錠します。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
プロジェクト保存 (.opensec)	全ワークスペースを単一ファイルに暗号化。	証拠品を金庫に納めて鍵をかける。
AES-256 暗号化	軍事機密レベルの厳重な機密保持。	決して破られないダイヤル錠。

> 🕵️ **探偵ミッション 16: 調査の暗号化保存**
> 「プロジェクトを保存」を選び、パスワードを設定して暗号化ファイルを保存します。

第 17章: 拡張ツールショップ (BApp コミュニティストア)

コミュニティ製拡張機能のワンクリック導入と独自JSONプラグインの作成。

> 🧩 **探偵のアタッチメント工房**
> リュックに新しい特殊ライトや特殊センサーを自由に追加できます。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
ワンクリック導入	プラグインを瞬時に有効化/無効化。	ベルトに新しい道具を装着する。
独自プラグインの読込	自作したJSON定義のツールを組み込み。	工房で自作した道具を装着する。

🕵️ 探偵ミッション 17: プラグインストアの体験

Plugins タブを開き、拡張機能を有効化して機能が追加される様子を確認します。

第 18章: SSL証明書、60日間評価期間、BTC $30 寄付 & 公式クレジット

HTTPS 検査用 X.509 ルート証明書、60日間の無制限評価期間、ビットコイン寄付レーダー。

> 🛡️ **外交特権パスポートと栄誉の銘板**
> 証明書は「この審査官を信頼してください」とブラウザに伝える外交官パスポートです。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
CA ルート証明書	HTTPS通信を警告なしで復号検査。	探偵の公式な封蝋印。
60日間の評価期間	再インストールでもリセットされない堅牢な60日間無制限試用。	2か月間の王国フリーパス。
ビットコイン 30 ドル寄付	Mempool レーダーによる自動入金検知と独立系ソフトウェア支援。	探偵ギルドへの連帯支援。
制作者クレジット	el saghet により誇りを持って設計・開発。	名匠の銘板が刻まれた証。

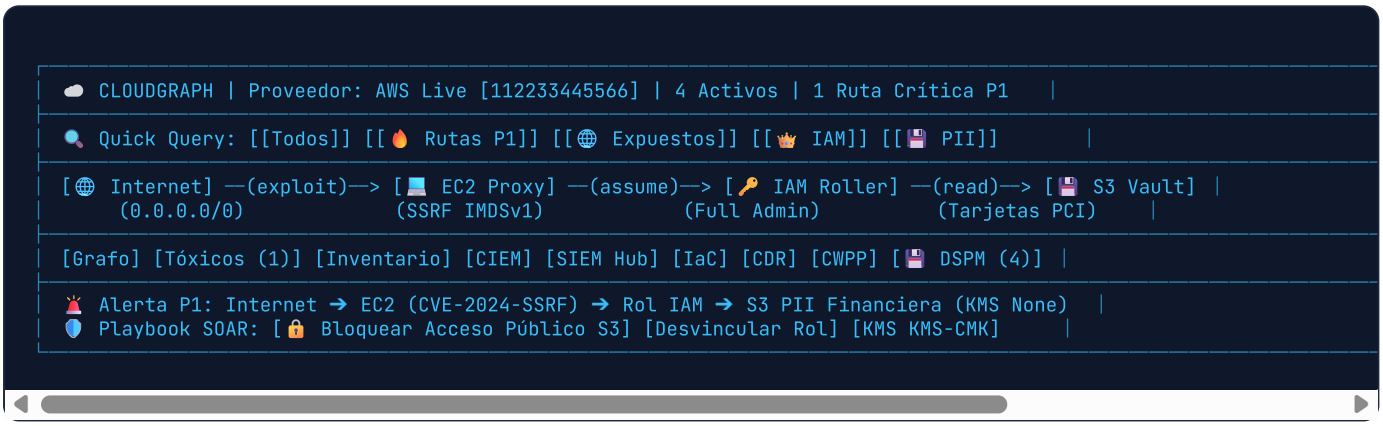
> 🕵️ **探偵ミッション 18: 公式銘板の確認**
> OpenSec Studio について を開き、開発者: el saghet • バージョン v1.10.10 公式エディションを確認してください。

第 19章: クラウド星図 (CloudGraph: CNAPP、Wiz エンジン、DSPM & SIEM ハブ)

Wiz アーキテクチャに着想を得た包括的クラウドセキュリティ診断 (CSPM、CIEM、CWPP、CDR、DSPM、IaC)。攻撃グラフを可視化し、トキシック・コンビネーションを相関分析。LocalStack エミュレータおよびオープンソース脆弱ラボを1クリックでロード。

> 🌌 **雲の上の浮遊都市と危険な複合リスクのレーダー**
>
> 複数のクラウド (AWS、Azure、GCP) に浮かぶ巨大な要塞を想像してください。CloudGraph はすべての門、橋、宝物庫を立体マッピングする 3D レーダーです。些細なアラートの山で混乱させることなく、「公開された門 ➔ 脆弱なサーバー ➔ 管理者マスターキー ➔ 機密データベース」という致命的な侵入経路だけを的確に探知します。

Topología y Grafo de Ataque Multidimensional (Wiz-like CNAPP):



セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
CyberGraph とクイック検索	攻撃経路グラフ画面と瞬時のフィルタチップ: [🔥 重大P1経路]、[🌐 公開+CVE]、[👑 特権IAM]、[💾 機密PII保管庫]。	侵入者が通れる本物の回廊だけを照らし出す熱源スコープ。
優先順位付けされたトキシックリスク	外部露出、悪用可能なCVE、過剰なIAM権限、機密データを複合相関分析する Wiz Core エンジン。	完全な侵入の条件: 開いた扉 + 壊れた鍵 + 合鍵 + 金庫。
CIEM と過剰特権の検知	未使用の特権アカウント、ワイルドカード権限、権限昇格リスクの洗い出し。	城の見習い兵が王室の金庫の鍵を持っている危険を発見する。
DSPM と機密データ保護	S3、Azure Blob、RDS 内のクレジットカード (PCI)、身元情報 (PII)、健康記録の高精度分類と1クリックKMS暗号化SOAR。	財宝を見つけ出し、直ちに魔法のKMS南京錠で施錠する税関検査。
CWPP とコンテナセキュリティ	コンテナレジストリ (ECR、ACR、GAR) のエージェントレス検査、埋め込みシークレット検出、OPA Gatekeeper 隔離。	船積み前のコンテナを全数検査し、危険物を隔離する港湾保安官。
CDR と MITRE ATT&CK for Cloud	CloudTrail や Azure Activity ログから攻撃者の戦術・技術をリアルタイム検知。	深夜に忍び込む不審者を捉える赤外線防犯センサー。
IaC Shift-Left セキュリティ診断	Terraform プラン (JSON) や Kubernetes マニフェスト (YAML) のデプロイ前事前監査。	基礎工事を始める前に設計図の欠陥を修正する建築検査。

セクション	OpenSec Studio での機能	わかりやすい例え (メタファー)
ローカルエミュレータとラボ (選択肢2 & 4)	LocalStack (localhost:4566)、Minikube 連携、OWASP CloudGoat、Terragoat、DVKS の1クリック読み込み。	実弾を消費せず安全に訓練できる無料の模擬演習場。
SIEM ハブ (Sentinel / Splunk)	検出された重大インシデントの自動連携と Sentinel KQL、Splunk SPL クエリの自動生成。	治安本部司令室へ直結した緊急通報ホットライン。

🕵️ 探偵ミッション 19: 脆弱クラウドラボを1クリックで診断する

CloudGraph を開き、「クラウド/IaCを接続」から「脆弱ラボ」を選び、「⚡ テストデータ / ラボ読込」を押して CyberGraph 上に赤く光るP1攻撃経路を確認します。